

TECNICATURA UNIVERSITARIA EN CIBERSEGURIDAD

SEGURIDAD EN EL CLOUD SERVICE

Migración a la nube



Dante Gabriel Balbuena Atar

Profesor: Velando Walter

Tucumán, Tafí Viejo – 11/09/2025

Contenido

1. INTRODUCCIÓN	3
2. DESARROLLO	3
3. CONCLUSIONES.....	5



1. Introducción

UGR Tech Secure, empresa dedicada al procesamiento de datos financieros y personales, se encuentra en un proceso de transformación digital que requiere la migración de sus sistemas a la nube. La operación se desarrolla en la Unión Europea (sujeta al Reglamento General de Protección de Datos – GDPR) y en América, particularmente en California, donde aplica la normativa CCPA/CPRA.

El desafío principal consiste en diseñar un plan integral que garantice seguridad, cumplimiento normativo y continuidad operativa, apoyándose en estándares internacionales como ISO/IEC 27017 (controles de seguridad en la nube) e ISO/IEC 27018 (protección de PII en nubes públicas).

Para este proyecto se selecciona Amazon Web Services (AWS) como proveedor en la región Irlanda (eu-west-1), debido a:

- Amplia certificación en estándares de seguridad y compliance.
- Capacidad de residencia de datos en la UE.
- Servicios nativos de seguridad y gestión de identidades.

2. Desarrollo

1. Análisis del Caso

Requisitos de Seguridad y Cumplimiento

- **GDPR:** residencia de datos en la UE, consentimiento, derecho al olvido, notificación de incidentes <72 horas.
- **CCPA/CPRA:** derecho a conocer, eliminar, y limitar uso de datos; transparencia frente a consumidores.
- **ISO/IEC 27017:** lineamientos de seguridad específicos en la nube (responsabilidades compartidas, segregación de clientes, controles de acceso).
- **ISO/IEC 27018:** principios de protección de PII (limitación de propósito, borrado seguro, trazabilidad de accesos).

2. Normativas ISO/IEC 27017 y 27018 aplicadas

- **ISO/IEC 27017:** establece prácticas de seguridad adicionales a la ISO/IEC 27002, enfocadas en entornos cloud. Incluye control de accesos, protección de datos en entornos virtualizados y segregación de roles.
- **ISO/IEC 27018:** proporciona directrices para proteger información de identificación personal (PII) en nubes públicas, incluyendo consentimiento, limitación de uso y gestión del ciclo de vida de datos.

3. Plan de Implementación de Controles

Controles Prioritarios

Norma	Control	Implementación en AWS
ISO/IEC 27017	Responsabilidad compartida	Uso del AWS Shared Responsibility Model y evidencias en AWS Artifact
ISO/IEC 27017	Protección de entornos virtuales	Amazon VPC, Security Groups, AWS Network Firewall
ISO/IEC 27017	Gestión de roles y accesos	AWS IAM, Organizations, MFA, IAM Identity Center
ISO/IEC 27018	Consentimiento y propósito	Amazon Cognito para registro de consentimiento, CMP externo integrado
ISO/IEC 27018	Borrado seguro de PII	S3 Lifecycle Policies, S3 Object Lock, cifrado con AWS KMS
ISO/IEC 27018	Auditoría y trazabilidad	AWS CloudTrail, AWS Config, GuardDuty, Security Hub

4. Responsabilidades Contractuales y Acuerdos

SLA (Service Level Agreement):

- Disponibilidad ≥ 99.9% en servicios críticos.
- Soporte 24/7 con tiempos de respuesta diferenciados.
- Garantía de redundancia multi-AZ.

DPA (Data Processing Agreement):

- Residencia obligatoria de datos de clientes europeos en eu-west-1.
- Uso de Cláusulas Contractuales Tipo (SCCs) para transferencias internacionales.
- Notificación de incidentes de seguridad dentro de las 72 horas (GDPR).

5. Evaluación de Riesgos

Matriz de Riesgos

Riesgo	Probabilidad	Impacto	Mitigación
Fuga de datos (PII/financieros)	Alta	Alto	Cifrado KMS, VPC aislada, monitoreo con GuardDuty
Misconfigurations	Alta	Medio	AWS Config, auditorías trimestrales, CloudFormation
Accesos privilegiados indebidos	Media	Alto	MFA obligatorio, IAM Identity Center, revisión de permisos
Interrupción de servicio	Media	Alto	Uso de varias AZs, backups automáticos, SLA 99.9%
Incumplimiento normativo	Baja	Alto	Políticas de privacidad, auditorías internas y externas

6. Auditoría

Auditoría interna:

- Trimestral, revisando logs de CloudTrail y configuraciones en AWS Config.
- Verificación del cumplimiento de GDPR y CCPA.

Auditoría externa:

- Anual, realizada por un tercero certificado.
- Evaluación de conformidad con ISO/IEC 27017 y 27018.

7. Desafíos y Soluciones

- Cumplimiento multirregional ➡ segmentación de datos por región + SCCs.
- Visibilidad de accesos y actividades ➡ CloudTrail centralizado + Security Hub.
- Gestión del ciclo de vida de claves de cifrado ➡ rotación automática en AWS KMS.

3. Conclusiones

La migración de UGR Tech Secure a AWS en la región de Irlanda permite cumplir con los requerimientos de seguridad, privacidad y normativa internacional. La adopción de controles basados en ISO/IEC 27017 y ISO/IEC 27018 asegura la protección de entornos virtuales y de PII, mientras que los acuerdos contractuales (SLA y DPA) establecen responsabilidades claras con el proveedor.

La implementación de servicios nativos de AWS, acompañada de políticas internas de seguridad y un plan de auditoría robusto, posiciona a la empresa en un marco de cumplimiento continuo, resiliencia y confianza para clientes y reguladores.

4. Referencias

Amazon Web Services. (s. f.). *Programas de cumplimiento en AWS*. AWS. Recuperado el 11 de septiembre de 2025, de <https://aws.amazon.com/es/compliance/programs/>

Amazon Web Services. (s. f.). *Preguntas frecuentes sobre ISO/IEC 27017*. AWS. Recuperado el 11 de septiembre de 2025, de <https://aws.amazon.com/es/compliance/iso-27017-faqs/>

Amazon Web Services. (s. f.). *Preguntas frecuentes sobre ISO/IEC 27018*. AWS. Recuperado el 11 de septiembre de 2025, de <https://aws.amazon.com/es/compliance/iso-27018-faqs/>

Google Cloud. (s. f.). *Cumplimiento de seguridad en la nube*. Google Cloud. Recuperado el 11 de septiembre de 2025, de <https://cloud.google.com/compliance?hl=es>

Google Cloud. (s. f.). *ISO/IEC 27018 en Google Cloud*. Google Cloud. Recuperado el 11 de septiembre de 2025, de <https://cloud.google.com/security/compliance/iso-27018?hl=es-419>

Microsoft. (s. f.). *Centro de confianza de Microsoft: Cumplimiento*. Microsoft Learn. Recuperado el 11 de septiembre de 2025, de <https://learn.microsoft.com/es-es/azure/compliance/>

Microsoft. (s. f.). *ISO/IEC 27017: Controles de seguridad para servicios en la nube*. Microsoft Learn. Recuperado el 11 de septiembre de 2025, de <https://learn.microsoft.com/es-es/azure/compliance/offerings/offering-iso-27017>

Microsoft. (s. f.). *ISO/IEC 27018: Protección de datos personales (PII) en nubes públicas*. Microsoft Learn. Recuperado el 11 de septiembre de 2025, de <https://learn.microsoft.com/es-es/azure/compliance/offerings/offering-iso-27018>